

**INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS
ACADEMY**

Week 1 Practical Laboratory

**Course: GRC102 – Information Security Governance
Module 1 – Principles of Information Security Governance**

Student Name: _ Jackline Maina

Reg. No: C11/26/CGRCE/17588

Date: __11/09/2026__

Table of Contents

Task 1: Governance Blueprint.....	3
1.1 Current- State Governance Gap Assessment.....	3
1.2 Proposed Governance Structure	3
1.3 Sample RACI Matrix.....	4
Task 2: Information Security Charter	5
2.1 Information Security Charter.....	5
2.1.1 Purpose.....	5
2.1.2 Scope.....	5
2.1.3 Authority	6
2.1.4 Roles and Responsibilities	6
2.1.5 Key Principles	6
2.1.6 Reporting Structure	6
2.1.7 Review and Approval.....	6
2.2 CFO Justification Memo	6
Task 3: Board Reporting and Security Metrics	7
3.1 Board Executive Summary	7
3.2 Selected Security Metrics	8
3.3 Priority Risks and Issues	9
3.4 Recommendations	10
3.5 Metric Selection Rationale	10
Task 4: Security Steering Committee (SSC)	11
4.1 Security Steering Committee Terms of Reference.....	11
4.2 Sample Agenda: First SSC Meeting.....	12
4.3 Briefing Note to the CEO	13
Task 5: Governance Maturity Assessment	14
5.1 Current Maturity Assessment	14
5.2 Governance Maturity Roadmap (12–18 Months).....	15
5.3 Executive Summary to the Board.....	16
References.....	17

Task 1: Governance Blueprint

1.1 Current- State Governance Gap Assessment

GHC's security governance is largely ad hoc, with unclear accountability, inconsistent policies, and reactive risk management. These weaknesses reduce oversight and increase operational, compliance, and reputational risk.

Government Gap Assessment Table

Gap	Current Issue	Risk
No dedicated security governance function	Security activities performed by IT Manager	Conflict of interest and weak oversight
Unclear accountability	Security ownership not formally assigned	Important tasks may be overlooked
Lack of formal reporting	No structured Board reporting	Leadership lacks visibility of security risks
Inconsistent policies	Acquired companies use different policies	Control gaps and compliance issues
Reactive risk management	Risks addressed after issues arise	Increased likelihood of incidents
Limited cross-functional coordination	Security decisions happen in silos	Business and security objectives misaligned

1.2 Proposed Governance Structure

The proposed structure introduces clear reporting lines and governance oversight through a dedicated Director of Information Security Governance and a Security Steering Committee. This improves coordination between business, technology, and compliance functions.

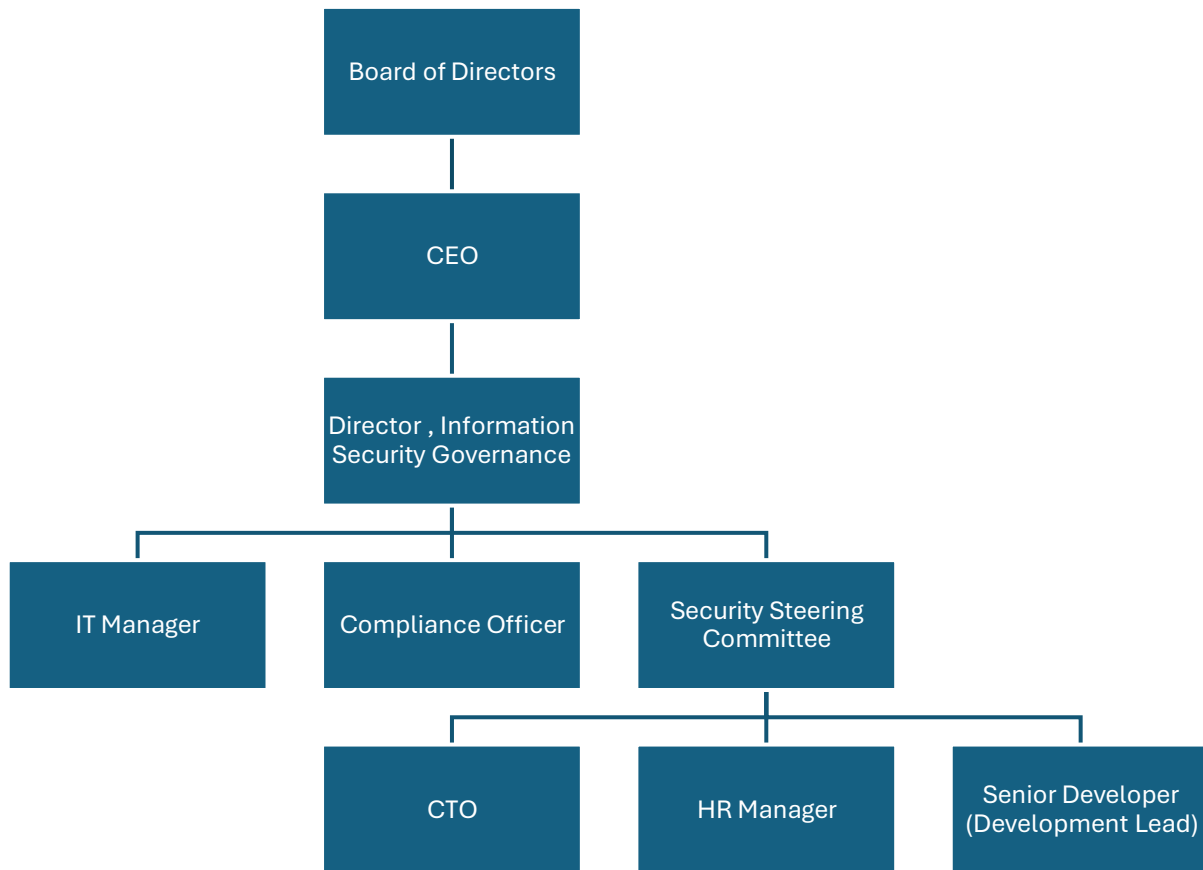


Figure 1: Proposed Information Security Governance Structure for GlobalHealth Connect (GHC).

1.3 Sample RACI Matrix

The RACI matrix assigns clear responsibilities for key governance activities such as policy approval, risk reviews, and incident response planning. This helps eliminate ambiguity and strengthens accountability across the organization.

Activity	Board	CEO	Director ISG	IT Manager	Compliance Officer	Security Steering Committe
Policy Approval	A	C	R	I	C	C
Risk Review	I	A	R	C	C	C
Incident Response Planning	I	A	R	R	C	C
Security Awareness Training	I	I	A	C	C	R
Compliance Monitoring	I	I	C	I	A/R	I
Board Reporting	A	C	R	I	C	I

A = Accountable, R = Responsible, C = Consulted, I = Informed

1.4 Government Structure Rationale

1.4.1 Accountability

Accountability is strengthened through clearly defined roles and responsibilities. The Board provides oversight, while management and governance functions are responsible for executing security objectives.

1.4.2 Transparency

Transparency is improved through formal reporting processes, documented responsibilities, and regular security governance reviews. This enables better visibility of risks and security performance.

1.4.3 Business Alignment

The governance model ensures security activities support GHC's strategic goals, including growth, compliance, innovation, and customer trust. Security decisions are therefore aligned with business priorities.

1.4.4 Risk Management

The proposed structure promotes proactive risk identification, assessment, and monitoring. This enables informed decision-making and more effective management of security risks.

Task 2: Information Security Charter

2.1 Information Security Charter

2.1.1 Purpose

The Information Security Program exists to protect GHC's information assets, patient data, and technology resources while supporting business growth, regulatory compliance, operational resilience, and customer trust.

2.1.2 Scope

This Charter applies to all employees, contractors, third parties, information assets, systems, networks, cloud services, and data managed or processed by GHC.

2.1.3 Authority

The Information Security Program operates under the authority of the Board and CEO. The Director of Information Security Governance is authorized to establish security requirements, conduct risk assessments, monitor compliance, and escalate significant security risks.

2.1.4 Roles and Responsibilities

- **Board of Directors:** Provides oversight and approves security strategy.
- **CEO:** Ensures executive support and resource allocation.
- **Director of Information Security Governance:** Leads governance, risk management, and reporting.
- **IT Manager:** Implements security controls and operational safeguards.
- **Compliance Officer:** Oversees regulatory and compliance requirements.
- **Security Steering Committee:** Provides cross-functional oversight and decision-making.

2.1.5 Key Principles

- Risk-based decision making
- Business alignment
- Accountability and transparency
- Regulatory compliance
- Continuous improvement
- Protection of patient information and organizational assets

2.1.6 Reporting Structure

Security performance, risks, incidents, and compliance status shall be reported regularly to management, the Security Steering Committee, and the Board of Directors.

2.1.7 Review and Approval

This Charter shall be approved by the CEO and Board of Directors and reviewed annually or following significant organizational or regulatory changes.

2.2 CFO Justification Memo

To: Marcus Thorne, Chief Financial Officer

From: Director of Information Security Governance

Subject: Information Security Charter Justification

The Information Security Charter establishes clear governance, accountability, and oversight for managing information security risks across GHC. By defining responsibilities, reporting structures, and decision-making authority, the Charter supports effective investment decisions and ensures security initiatives align with business objectives.

The Charter directly supports GHC's strategic goals by protecting customer trust, strengthening regulatory compliance, enabling secure innovation, and supporting sustainable growth. It also provides management with a consistent framework for evaluating risks, prioritizing resources, and measuring security performance.

Task 3: Board Reporting and Security Metrics

3.1 Board Executive Summary

Board Security Dashboard

Metric	Trend	Status
Phishing Attempts	↑ Increasing	● Red
Malware Incidents	↑ Increasing	● Red
Patching Rate	↓ Declining	● Red
Training Completion	↑ Improving	● Green
High-Risk Incidents	↑ Increasing	● Red

Overall Security Posture: RED

The overall security posture of GHC is assessed as **RED**. Over the six-month reporting period, phishing attempts increased from 150 to 320, malware incidents increased from 25 to 50, and high-risk incidents increased from 2 to 7. At the same time, patching effectiveness declined from 67% to 55%, increasing exposure to known vulnerabilities. Although security awareness training improved from 45% to 70%, current controls are not effectively reducing overall cyber risk. Immediate management attention is required to strengthen vulnerability management and improve resilience against evolving threats.

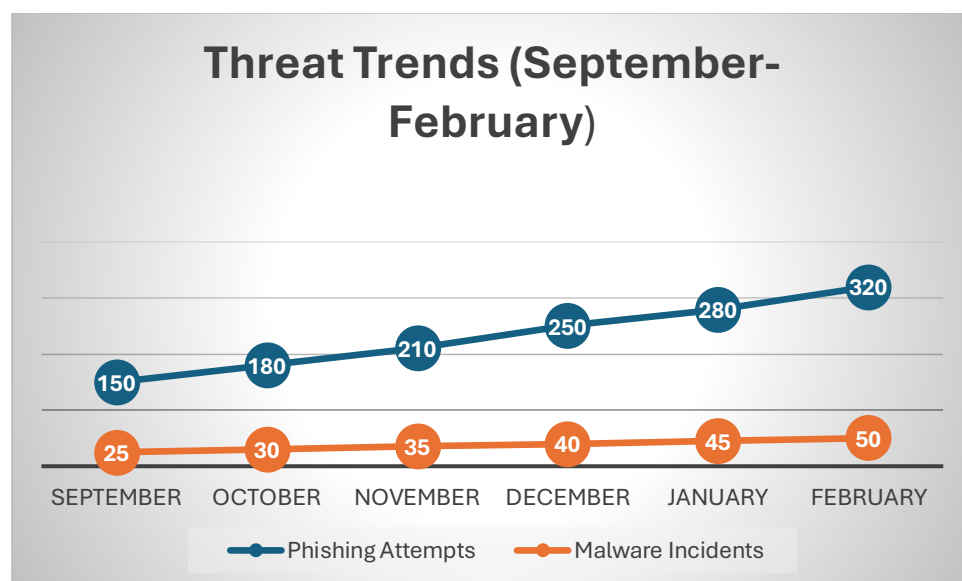
3.2 Selected Security Metrics

Security Metrics Summary

Metric	September	February	Trend	Business Commentary
Phishing Attempts	150	320	↑ Increasing	Higher likelihood of credential theft and data breaches
Malware Incidents	25	50	↑ Increasing	Increased operational disruption risk
Patching Rate	67%	55%	↓ Declining	Higher exposure to known vulnerabilities
Training Completion	45%	70%	↑ Improving	Improved security awareness
High-Risk Incidents	2	7	↑ Increasing	Increased business and security risk

Figure 2: Threat Trends (September-February)

To assess changes in threat exposure, the Board reviewed trends in phishing attempts and malware incidents over the six-month reporting period. Figure 2 summarizes the observed increase in threat activity and its potential impact on organizational risk.

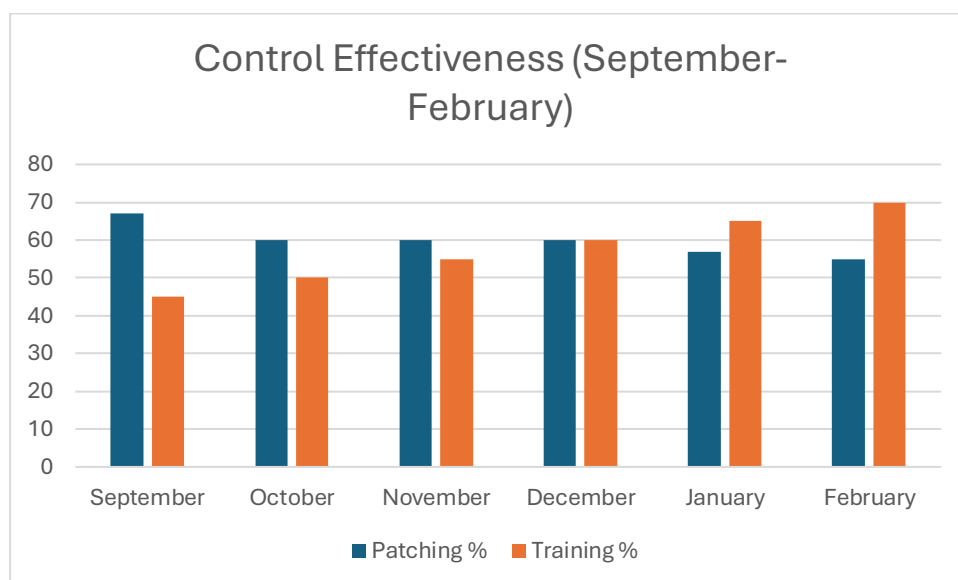


Analysis

Phishing attempts and malware incidents increased consistently throughout the reporting period, indicating growing exposure to cyber threats and increasing pressure on existing security controls.

Figure 3: Control Effectiveness (September-February)

To evaluate the effectiveness of key security controls, the Board reviewed trends in patching compliance and security awareness training completion. Figure 3 highlights improvements in employee awareness while identifying a decline in patch-management performance.



Analysis

While security awareness training improved significantly from 45% to 70%, patching effectiveness declined from 67% to 55%. This indicates positive progress in building a security-aware culture, but weaknesses remain in vulnerability remediation and patch management processes.

3.3 Priority Risks and Issues

Risk 1: Vulnerability Management Weaknesses

Declining patching rates have resulted in an increasing number of unresolved critical vulnerabilities, raising the likelihood of system compromise, service disruption, and regulatory non-compliance.

Risk 2: Increasing Social Engineering Threats

The significant increase in phishing activity elevates the risk of credential theft, unauthorized access, and potential exposure of sensitive patient information.

3.4 Recommendations

Recommendation 1: Strengthen Vulnerability Management

Implement a formal vulnerability management program with defined service-level targets and a goal of maintaining at least **90% patch compliance** for critical vulnerabilities. Progress should be reported monthly to executive management.

Recommendation 2: Enhance Phishing Defenses

Strengthen phishing resilience through continuous awareness campaigns, simulated phishing exercises, and mandatory multi-factor authentication (MFA) for all users with access to corporate systems.

3.5 Metric Selection Rationale

The selected metrics provide Board-level visibility into key areas of security governance. Phishing attempts and malware incidents measure threat exposure, patching rate measures control effectiveness, training completion reflects workforce awareness, and high-risk incidents demonstrate business impact. Together, these metrics provide meaningful insight into GHC's overall security posture and support informed decision-making regarding risk treatment, security investments, and governance oversight.

Task 4: Security Steering Committee (SSC)

4.1 Security Steering Committee Terms of Reference

Purpose

The Security Steering Committee (SSC) provides strategic oversight of information security activities, resolves cross-functional security issues, and ensures alignment between security objectives and business goals.

Scope

The SSC oversees information security governance, security policies, risk management, compliance, security initiatives, and significant security-related decisions across GHC. It also serves as the forum for resolving conflicts involving security requirements and business operations

Membership

- CEO (Chair)
- Director of Information Security Governance
- CTO
- IT Manager
- Compliance Officer
- HR Manager
- Senior Developer (Development Lead)

Responsibilities

The SSC shall:

- Review security risks and governance activities.
- Review and recommend security policies and standards.
- Resolve cross-functional security conflicts.
- Monitor security performance and metrics.
- Prioritize security initiatives and investments.
- Support compliance and risk management objectives.

Meeting Cadence

The SSC shall meet monthly and may hold ad-hoc meetings when significant security risks, incidents, or urgent matters require executive attention.

Decision Authority

The SSC may recommend policy changes, approve security initiatives within delegated authority, and escalate strategic decisions requiring executive or Board approval.

Reporting

The SSC shall provide quarterly security governance updates to executive management and the Board of Directors.

4.2 Sample Agenda: First SSC Meeting

Security Steering Committee Meeting #1

Date: *mm/dd/yyyy*

Chair: CEO

Agenda

1. Opening Remarks and Meeting Objectives
2. Review of Current Security Posture
3. Review of Security Metrics and Key Risks
4. Discussion of Proposed Password Policy
 - ✓ IT Manager perspective
 - ✓ CTO perspective
 - ✓ Business impact assessment
 - ✓ Industry best practices review
5. Committee Recommendation and Decision
6. Review of Security Initiatives and Priorities
7. Action Items and Next Steps
8. Meeting Close

Recommended SSC Decision

The committee supports the CTO's recommendation to adopt MFA, password manager integration, and strong passphrases in place of mandatory 30-day password resets.

Password changes will also be enforced following suspected or confirmed compromise. This approach provides effective security while maintaining usability and business productivity.

4.3 Briefing Note to the CEO

To: Sarah Chen, CEO

From: Director of Information Security Governance

Subject: Role of the Security Steering Committee in Resolving Security Governance Conflicts

The Security Steering Committee provides a formal governance mechanism for resolving cross-functional security issues by bringing together representatives from business, technology, compliance, and operational functions. Through structured discussion and risk-based decision-making, the committee ensures that security decisions consider both security requirements and business objectives.

In the case of the proposed password policy, the SSC will evaluate the security benefits, operational impact, and industry best practices before reaching a decision. This approach promotes accountability, transparency, and strategic alignment while ensuring that security controls support GHC's goals of operational efficiency, customer trust, innovation, and regulatory excellence.

Regards,

Director of Information Security Governance

GlobalHealth Connect (GHC)

Task 5: Governance Maturity Assessment

5.1 Current Maturity Assessment

Governance Domain	Current Level	Justification
Policy & Documentation	Level 2 (Initial)	Policies exist but are inconsistent, inherited from acquisitions, and not regularly updated.
Roles & Responsibilities	Level 1 (Ad Hoc)	Security ownership and accountability are unclear, resulting in inconsistent governance.
Risk Management	Level 1 (Ad Hoc)	Risk management is reactive and lacks a formal assessment process.
Metrics & Reporting	Level 2 (Initial)	Technical metrics are collected but are not consistently linked to business impact.
Training & Awareness	Level 2 (Initial)	Training exists but employee engagement remains low.
Compliance	Level 2 (Initial)	Compliance activities are largely audit-driven rather than continuously monitored.

Maturity Assessment Summary

GHC currently operates between **Level 1 (Ad Hoc)** and **Level 2 (Initial)** across most governance domains. While some foundational practices exist, governance activities remain inconsistently applied, reactive, and insufficiently documented. Significant improvements are required to achieve a consistent and defined governance framework.

5.2 Governance Maturity Roadmap (12–18 Months)

Initiative	Objective	Key Activities	Measurable Outcome
Governance Framework Implementation	Establish clear governance accountability and oversight.	Establish governance structure, define reporting lines, and formalize the Security Steering Committee.	All governance roles documented and approved.
Policy & Documentation Standardization	Create a consistent and current policy framework.	Review inherited policies, update outdated documents, and implement annual policy reviews.	100% of security policies reviewed and approved.
Risk Management Program	Transition from reactive to proactive risk management.	Develop a risk register, conduct quarterly risk assessments, and track remediation activities.	Quarterly risk assessments completed and reported.
Metrics & Reporting Enhancement	Improve executive visibility of security performance.	Develop Board-level KPIs/KRIs and establish regular security reporting.	Quarterly Board security reports produced.
Security Awareness & Compliance Improvement	Strengthen security culture and compliance monitoring.	Conduct awareness campaigns, phishing simulations, and continuous compliance monitoring.	Training completion above 95% and improved audit outcomes.

5.3 Executive Summary to the Board

GHC's current governance maturity is assessed between **Level 1 (Ad Hoc)** and **Level 2 (Initial)**. While certain governance activities are in place, many processes remain informal, reactive, and inconsistently applied. Key weaknesses include unclear accountability, fragmented policy management, reactive risk management, and limited translation of security metrics into business-focused reporting.

The proposed 12–18 month roadmap is designed to achieve **Level 3 (Defined)** maturity across all governance domains by establishing formal governance structures, standardizing policies, implementing proactive risk management, enhancing reporting capabilities, and strengthening security awareness. Achieving this maturity level will support regulatory compliance, improve risk visibility, increase operational resilience, and align information security more effectively with GHC's strategic business objectives.

References

ISACA. (2019). COBIT 2019 Framework: Governance and Management Objectives.

ISO/IEC 27001:2022. Information Security, Cybersecurity and Privacy Protection — Information Security Management Systems — Requirements.

National Institute of Standards and Technology (NIST). (2024). Cybersecurity Framework (CSF) 2.0.

NIST. (2012). Special Publication 800-61 Rev. 2: Computer Security Incident Handling Guide.

NIST. (2020). Special Publication 800-63B: Digital Identity Guidelines – Authentication and Lifecycle Management.